

PUBLIC COMMENT

Response to Request for Information: Accelerating the Adoption and Use of
Artificial Intelligence as Part of Clinical Care
90 FR 60108 | RIN 0955-AA13 | Docket HHS-ONC-2026-0001

Submitted by: Abdullah Darvesh, MD

Capacity: Physician-Founder, CitaCell Health Solutions; PGY-III Internal Medicine Resident

Additional roles: Incoming Informatics Lead, NIH-funded NCORP Grant, Gibbs Cancer Center; Incoming Student, Duke Master of Management in Clinical Informatics (July 2026); Lecturer, Informatics in Medicine—Ethics, AI and More, USC School of Medicine (April 2026)

Date: February 22, 2026

I. Introduction

I am a third-year internal medicine resident who writes clinical orders on real patients every day. I am also the founder of CitaCell Health Solutions, a healthcare AI compliance infrastructure company with a patent-filed architecture called the Artificial Cellular Organization (ACO). I submit this comment as both a frontline clinician who has spent three years observing AI's accelerating impact on clinical medicine and as a technical practitioner who has channeled that experience into engineering a concrete solution to the data exposure problem this RFI seeks to address.

My perspective may be useful to HHS because I sit at an intersection that few commenters occupy simultaneously: I experience the clinical workflow that AI tools must integrate into, I understand the data architecture that makes integration possible, and I am actively building the security infrastructure that should govern the boundary between the two. I believe this RFI is asking the right questions. I also believe the agency may be missing a critical perspective—specifically, the perspective of clinicians who understand what data actually needs to cross trust boundaries for AI to function, versus what data currently crosses those boundaries simply because no one with clinical judgment is governing the scope.

II. Background: The Specific Problem This Comment Addresses

This comment addresses the intersection of three areas within the RFI: regulation (specifically, whether current data protection frameworks are adequate for AI-integrated clinical environments), reimbursement (whether payment policy can incentivize structurally secure AI adoption), and research and development (whether HHS should fund investigation into architecture-based data protection as a complement to policy-based protection).

The RFI correctly identifies that HHS seeks to “protect patients and the confidentiality of their identifiable health information” while accelerating AI adoption. The implicit assumption in this framing—shared by most current compliance frameworks—is that these goals are in tension: more AI means more data exposure, which means more risk, which means more protective policy. I submit that this tension is an artifact of the current architectural paradigm, not an inherent property of AI integration. If the architecture is redesigned so that identifiable patient data never exists in exploitable form outside the health system’s trust boundary, then AI adoption and patient protection become structurally aligned rather than structurally opposed.

I address below the RFI’s ten specific questions, grouped thematically where they intersect, and provide specific recommendations with relevant regulatory citations.

III. Analysis: Responses to Specific RFI Questions

Question 1: Barriers to Private Sector Innovation and Adoption

I can describe this barrier from direct experience. When I began building an AI-powered revenue cycle management tool for a multi-site allergy practice, the first question from the practice owner—a physician—was not about accuracy or cost. It was: “Where does my patient data go?” He had already evaluated three AI vendors. Each required access to complete patient records, including names, dates of birth, and medical record numbers, to perform functions that do not require any of that information. Identifying a CPT coding gap requires procedure codes, diagnosis codes, and documentation elements. It does not require knowing who the patient is.

This physician’s hesitation is rational, not irrational. Under current frameworks, adopting an AI tool means sending identifiable PHI to a system he does not control, governed by a Business Associate Agreement he cannot enforce in real-time. His options are binary: full data exposure or no AI. That is the barrier. It is not regulatory burden, and loosening compliance will not resolve it. What resolves it is an integration architecture where the AI vendor receives only the de-identified, scoped data elements its analytical function requires—and where even those elements are architecturally protected so that no single system outside the trust boundary holds enough information to reconstruct a patient record. I built this. It works. The barrier disappears when the architecture changes, not when the policy relaxes.

Question 2: Regulatory and Payment Policy Changes HHS Should Prioritize

Regulatory recommendation 1: Recognize “Structural Compliance” as a distinct tier above the HIPAA Security Rule baseline. The HIPAA Security Rule (45 CFR Part 164, Subpart C) requires administrative, physical, and technical safeguards for ePHI. These safeguards assume ePHI exists within systems and must be protected by controls. HHS should recognize a voluntary designation for systems in which the architecture itself prevents ePHI from existing in exploitable form—where security is achieved through structural nonexistence of data rather than

structural protection of data. This is not a replacement for HIPAA. It is a higher tier for AI integration contexts where data crosses trust boundaries to external vendors.

Regulatory recommendation 2: Update the Safe Harbor de-identification standard at 45 CFR 164.514(b). The current Safe Harbor method lists 18 identifier categories for removal. Published research has demonstrated that individuals can be re-identified with as few as four data points not included in this list. As AI vendors ingest increasingly granular clinical data—procedure timestamps, medication dosing patterns, lab result trajectories—the re-identification surface expands beyond what Safe Harbor currently addresses. More fundamentally, de-identification alone is insufficient when the underlying architecture still transmits complete, correlated clinical records to external systems. A structurally secure architecture should provide independent protection layers beyond de-identification—ensuring that even de-identified data cannot be reassembled into a complete clinical record by any single system.

Payment policy recommendation: Create a Promoting Interoperability or MIPS quality component for structural PHI protection in AI integration. Payment policy is HHS’s most powerful lever. If CMS recognized structural data protection as a measurable quality indicator—analogue to how Promoting Interoperability incentivizes FHIR R4 adoption and e-prescribing—health systems would have direct financial incentive to deploy architecturally secure AI integration layers rather than relying solely on BAA-governed data sharing. This would shift the market from competing on policy documentation to competing on architectural security.

Question 3: Novel Legal and Implementation Issues for Non-Medical Device AI

The most critical novel issue is what I call the trust boundary problem. When a non-device AI tool processes clinical data, that data crosses from the covered entity’s infrastructure into the vendor’s infrastructure. Under 45 CFR 164.502(e), this crossing is governed by Business Associate Agreements—contractual instruments that define obligations but do not change the structural fact that identifiable data now exists in a system the covered entity does not control. The BAA does not prevent the breach. It defines who is liable after the breach occurs.

From clinical practice, I can describe what this looks like on the ground. An ambient AI scribe requires microphone access to the entire patient encounter and direct write access to the clinical note. The vendor’s system processes the full audio—including the patient’s name, diagnosis, and every detail discussed in the room—on external servers. The physician has no visibility into how that audio is stored, for how long, or who else can access it. The BAA says the vendor will protect it. But the data is there, in the clear, in someone else’s infrastructure. If that vendor is compromised, every patient encounter processed through the system is exposed. No policy prevents this. Only architecture can—by ensuring the vendor never receives identifiable data in the first place, or by mediating the return path so that vendor outputs never directly enter the clinical record without independent validation.

HHS should consider whether middleware that mediates AI vendor integration should be held to architectural standards governing both outbound data scoping (what leaves the trust boundary) and inbound result validation (what re-enters the clinical record). The architecture I have developed and filed patents on implements both: outbound data is scoped and protected so identifiable information never reaches the vendor; inbound results are independently validated before entering the clinical record rather than being accepted as vendor-written data.

Question 4: Most Promising AI Evaluation Methods

Pre-deployment: Evaluate the data exposure surface before evaluating the model. Before assessing whether an AI model performs well, HHS should require assessment of how much PHI the model receives. Does the vendor receive the minimum data elements required for its analytical function? Is the data de-identified? Does the architecture prevent any single external system from reconstructing a complete patient record? These are binary, testable architectural questions—more actionable and more protective than probabilistic model performance benchmarks.

Post-deployment: Deterministic replay audits, not log reviews. The most promising post-deployment method is deterministic audit—where the audit trail is a recipe for reconstruction rather than a recording. If the same inputs under the same rules produce the same output, compliance can be verified by replay rather than by reviewing logs that may be incomplete or tampered with. This makes audit contemporaneous with each transaction rather than retroactive. Proven cryptographic methods exist to implement this. HHS should support development of these evaluation tools through cooperative agreements (CRADAs) so health systems can apply them to any AI integration, not just specific models.

Question 5: Supporting Private Sector Activities

Credentialing: Establish a Clinical AI Architect competency pathway. The individuals governing what patient data crosses trust boundaries for AI processing should hold demonstrated competency in clinical medicine, health informatics, and security architecture. The closest existing credential is the ABPM clinical informatics subspecialty, which covers informatics broadly but does not address the specific architectural security implications of AI integration. HHS should support development of a credential—through ASTP/ONC or in partnership with specialty boards—that certifies individuals to govern the clinical-data-to-AI pipeline. The people scoping what data an AI vendor receives should be clinicians, not IT procurement teams.

Certification: Support industry-led structural compliance evaluation. HHS should encourage—without prescribing—industry-led certification programs that evaluate AI integration layers against structural compliance criteria: nonexistence of exploitable PHI, zero-trust architecture including self-trust, compounding security across independent domains, and

deterministic auditability. This parallels how ASTP/ONC supports but does not directly administer health IT certification.

Question 6: Where AI Has Met or Fallen Short of Expectations

From direct experience deploying AI for revenue cycle management in a specialty allergy practice: AI has met expectations in bounded analytical tasks with quantifiable ROI—identifying CPT coding gaps, flagging modifier errors, detecting authorization discrepancies, and estimating documentation-driven revenue recovery. In one case, an AI-identified authorization discrepancy on a biologic medication (Xolair) flagged a documentation pattern that had resulted in approximately \$77,000 in unrecovered revenue over the prior year. The analytical function worked because the task was well-defined, the scope was narrow, and the output was actionable without ambiguity.

Where AI has consistently fallen short is in clinical decision support—and the failure mode is instructive for HHS. Most clinical AI tools are designed and implemented by teams without clinical workflow experience. The result is what I would call the bells-and-whistles problem: tools that generate alerts, suggestions, and documentation requirements that physicians must then review, verify, override, or acknowledge. Rather than reducing cognitive burden, these tools effectively turn the physician into an auditor of the AI’s output. The physician’s clinical time is redirected from patient care to managing the AI system itself—clicking through alerts, correcting autogenerated notes, reconciling AI suggestions against clinical judgment. This is the opposite of the productivity gain these tools promise.

The downstream effect is measurable: more documentation burden, more clicks per encounter, more time spent on compliance with the tool rather than on clinical reasoning. Health systems adopt these tools expecting cost reduction and receive cost displacement—the labor shifts from administrative staff to physicians, who are the most expensive personnel in the organization. When the individuals implementing AI tools do not understand clinical workflows, the tools create bloat rather than efficiency. HHS should recognize that AI adoption is not inherently beneficial—it is beneficial only when the tools are designed around clinical workflow realities, governed by clinicians who understand those workflows, and evaluated against meaningful clinical efficiency metrics rather than vendor-defined performance benchmarks.

The novel AI tools with greatest potential are not clinical decision support overlays but structural compliance layers—integration middleware that enables health systems to engage any AI vendor safely by controlling data exposure at the architectural level. The greatest cost reduction will not come from any individual AI model but from the elimination of breach-related liability, which costs healthcare organizations an average of \$10.93 million per breach according to the IBM Cost of a Data Breach Report (2023, healthcare sector), and from the reduction of physician time wasted auditing poorly designed AI outputs.

Question 7: Influential Roles and Administrative Hurdles

In the practices I work with, AI adoption decisions are driven by practice administrators, IT consultants, and vendor sales teams. The physician's role typically enters late—as a usability reviewer, not as a data governance authority. The most consequential decision in any AI integration—what patient data will cross the trust boundary, in what form, and for what analytical scope—is made without clinical input.

This is backwards. A clinician who understands why a hemoglobin A1c is ordered, what it means for a specific patient's trajectory, and which elements of that clinical context are actually required for a given AI inference is the only person qualified to determine what data should leave the trust boundary. I call this principle “selective minimum information extraction”: the AI receives only the specific, de-identified data elements required for its analytical function, and a clinician with informatics training governs that scope determination.

HHS should encourage health systems to establish Clinical AI Governance roles—held by practicing clinicians with informatics competency—with authority over data scoping decisions for AI integrations. The primary administrative hurdle is not technology or cost. It is the absence of an organizational role that places clinical judgment at the center of AI data governance.

Question 8: Enhanced Interoperability

FHIR R4 interoperability is essential for AI adoption, but it also widens the data exposure surface. FHIR makes it technically straightforward to extract comprehensive patient records and route them to external AI systems. This is a feature for clinical care coordination and a vulnerability for AI vendor integration. HHS should pair interoperability incentives with structural protection requirements for data that crosses trust boundaries for AI processing.

Specific gap: There is no FHIR-based standard for exchanging structural compliance attestations, governance proofs, or architectural audit metadata alongside clinical data. When a health system routes data to an AI vendor through a middleware layer, there is no interoperable way for the receiving system to verify the sender's data protection architecture, or vice versa. HHS should sponsor development of a FHIR Implementation Guide for structural compliance attestations—enabling systems to verify each other's architectural protections in-band rather than relying on out-of-band contractual assurances.

Question 9: Patient and Caregiver Concerns

From conversations with patients in my own practice: patients do not object to AI being used in their care. They object to not knowing where their data goes. When I explain that an AI tool helped flag a potential medication interaction, the response is positive. When I explain that the tool required sending their full medical record to an external company's server, the response changes. The concern is not AI capability—it is data exposure.

More consent forms will not address this concern. Patients are already overwhelmed by paperwork they do not read. What patients deserve is an architecture where AI integration does not require them to accept data exposure as a condition of receiving technologically enhanced care. If the AI vendor never receives identifiable data—if the architecture makes it structurally impossible for the vendor to know who the patient is—then the consent question becomes moot. That is the standard patients deserve, even if they do not yet have the vocabulary to demand it.

Question 10: Priority Areas of AI Research

Priority 1: Clinician-led AI data governance. HHS should fund research into how clinician-governed data scoping affects breach rates, data exposure surface, and AI output quality. The hypothesis: selective minimum information extraction—where clinicians determine the minimum data elements an AI vendor receives—improves both security and AI performance by reducing noise in the input data. Multi-site studies through existing research networks, including NIH NCORP, could validate this.

Priority 2: Architecture-based data protection. The ACO architecture I have developed derives its structural properties from biological immune systems—not as metaphor but as engineering specification. Biological systems have solved the core security problems healthcare AI governance faces over billions of years of evolutionary pressure: share precisely what is needed, verify without trusting, and ensure that compromise of any single component cannot compromise the whole. HHS should fund applied research into bio-inspired security architectures for healthcare data, including formal verification of biological design principles translated into computational security properties.

Priority 3: Structural compliance measurement. No validated framework exists for measuring whether an AI integration achieves structural compliance—whether data breaches are architecturally impossible rather than merely policy-restricted. HHS should fund development of measurement tools and testing methodologies, analogous to how NIST provides measurement frameworks for cryptographic implementations.

Existing evidence: The IBM Cost of a Data Breach Report (2023) documents healthcare as the highest-cost sector for breaches at \$10.93M average per incident. The Ponemon Institute’s healthcare cybersecurity studies consistently show that policy-based controls reduce but do not eliminate breach frequency. Healthcare has been the most breached industry for over a decade under the current policy-based paradigm. The literature supports investigating a paradigm shift toward architecture-based protection.

IV. Recommendations

Based on the analysis above, I recommend the following specific actions:

- 1. Recognize Structural Compliance as a distinct, voluntary tier of data protection above HIPAA and SOC 2**, applicable to AI integration contexts where clinical data crosses trust boundaries to external vendors. Systems meeting this tier would demonstrate that patient data in any persistent, addressable, complete form never exists within the AI processing pipeline—enforced by architecture, not policy.
- 2. Update the Safe Harbor de-identification standard at 45 CFR 164.514(b)** to address AI-era re-identification risks from high-dimensional clinical datasets, and recognize that de-identification alone is insufficient without additional architectural protections that prevent reconstruction of complete patient records.
- 3. Create a CMS payment incentive (Promoting Interoperability or MIPS component) for structural PHI protection in AI integration**, shifting market incentives from policy documentation to architectural security.
- 4. Encourage development of a Clinical AI Architect credential** through ASTP/ONC or specialty board partnerships, requiring competency in clinical medicine, health informatics, and security architecture.
- 5. Fund NIH research into clinician-led AI governance, bio-inspired security architectures, and structural compliance measurement**, using existing multi-site research networks including NCORP.
- 6. Sponsor development of a FHIR Implementation Guide for structural compliance attestations**, enabling interoperable verification of data protection architecture between health systems, middleware, and AI vendors.
- 7. Issue guidance clarifying that middleware mediating AI vendor integration should meet architectural standards** governing both outbound data scoping and inbound result validation—not just contractual standards under BAAs.

V. Conclusion

This RFI asks the right question: how can HHS accelerate AI adoption in clinical care while protecting patients? The answer most commenters will offer is better policy—more guidelines, updated regulations, clearer liability frameworks. I offer a different answer: better architecture. Policy governs behavior around data that exists. Architecture determines whether data exists in exploitable form at all. In an AI-integrated healthcare environment where clinical data routinely crosses trust boundaries to external vendors, architecture is the more fundamental lever.

After three years of observing how AI is transforming clinical medicine—and how current compliance frameworks fail to protect patients in that transformation—I built a concrete implementation of this principle: the Artificial Cellular Organization, a patent-filed architecture

that derives its security properties from biological immune systems. It is not the only possible implementation, but it demonstrates that structural compliance is achievable, testable, and deployable in clinical settings. A pilot deployment at a multi-site allergy practice is scheduled for May 2026.

The perspective I bring—a practicing physician who builds the security infrastructure for the AI tools he uses in clinical care—is precisely the perspective this process is designed to capture: how a proposed policy direction would impact someone operating on the ground. From the ground, I can report that the current compliance paradigm is not adequate for AI-integrated clinical care, that structural alternatives exist, and that HHS has the regulatory and payment policy levers to incentivize their adoption.

I am available to provide further technical detail, demonstrate the ACO architecture, or contribute to any working group or advisory process the Department may convene.

Respectfully submitted,

Abdullah Darvesh, MD

Founder & CEO, CitaCell Health Solutions